研究内容・手法・結果・限界

APK の静的情報と実行時通信を証拠に基づいて説明する

解析支援システムの設計と、既存 25 試行による事例評価

25	端末試行
1	公開アプリ
AI	原本・結果の点検

URL 候補があることと、通信したことは違う

静的情報

APK に含まれる候補

実行されたかは
別に確認する

実行時の通信

操作中に観測した記録

全機能を網羅しない

不足する情報

帰属・時刻・取得範囲

推測で埋めない

必要なのは、候補・実測・不足を区別して説明すること。

出典：論文草稿・ AntennaPod 通常起動／ RSS 事例

研究目的は「比較説明」と「根拠の追跡」

RQ1	指定範囲の解析を実行し、失敗した段階も説明できるか
RQ2	静的のみ・動的のみ・併用で、説明できる範囲はどう違うか
RQ3	不明・未観測・取得失敗を、根拠のない断定へ変換しないか

「比較できること」と「ポリシー違反を判定できること」は別。

出典：研究デザイン RQ1–RQ3

APK 入力から説明レポートまでをつなぐ

入力

APK
操作シナリオ
任意の条件

静的解析

権限・設定・ URL 候補

動的観測

指定操作中の通信

比較・状態整理

対応する?
実測だけ?
判断できる?

説明と根拠

比較レポート
証拠索引
原本への参照

対象は指定した操作と観測窓。すべての画面・通信を自動探索する仕組みではない。

出典：実装モジュール・現在のシステム構成図

1 件の通信でも、 4 つの状態を分ける

観測

通信試行／接続
HTTP ／未観測
取得失敗

帰属

対象／別 UID
不明

可視性

メタデータ
確認できた範囲

判定

整合／不一致候補
要確認／評価不能

例：通信は見えても、対象アプリのものと確認できなければ保留する。

出典：状態モデル・照合規則 C02 ／ C05 ／ C07

25 試行を、役割ごとに分けて評価する

データ群	試行数	評価上の役割
初期 CSV 制御	13	HTTP ・ UDP ・通信なし
追加制御	6	HTTP 処理不成功・専用信頼 HTTPS
自動 HTTP PCAP	1	自動取得から比較までの経路
公開アプリ起動	1	実アプリの起動窓
公開アプリ RSS	4	表示・追加操作・状態記録の事例

単一 AVD ・公開アプリ 1 本・全品質 partial 。一般精度の標本ではない。

出典：既存 25 試行の台帳（ trials-25.csv ）

比較するのは、同じ証拠から得られる説明

S： 静的のみ

APK 内の宣言・候補
通信の実行は断定しない

D： 動的のみ

指定窓の通信と取得条件
静的な候補は分からない

SD： 併用

両方の根拠を並べて対応差と不足を説明する

別の比較： UID 不明を「保持」「削除」「 UID 条件だけ除去」した場合の出力差

原本・画面・サーバー記録を、解釈の検証資料として使う。

出典： 3 方式比較・ UID 構成要素比較

自動 HTTP では、対応あり 1 ・静的候補のみ 1

対応あり： 1

APK 内の宛先候補
＋ 対象 UID の HTTP 通信
→ 対応する根拠を提示

静的候補のみ： 1

APK 内の別の候補
→ この窓では対応未観測
→ 未使用とは断定しない

取得・比較の経路は成立。ただし未指定ポリシーは「要確認」のまま。

出典： auto-http-002 原本検証・ correspondence.json

公開アプリでは、静的候補と実測の範囲が違う

項目	通常起動	RSS プレビュー 006
静的な宛先候補	38 組	38 組
対象 UID のフロー	0	2
対象の実測宛先	未観測	ローカルの 1 組
読み取れること	候補と実測は別	実行時入力の宛先を観測

「動的のみ」は異常の意味ではない。実行時入力でも自然に生じる。

出典： AntennaPod 3.12.3 起動 001 ／ RSS006

HEAD と GET を区別すると、結果の意味が変わる

RSS006： 表示の事例

RSS GET： 679 B
音声 HEAD： 本文 0 B
音声 GET： 保持記録では未観測

RSS001： 追加操作を含む

RSS 本文： 679 B
音声 GET 本文： 16,044 B
購読・再生等の申告あり

音声 HEAD の Content-Length 16,044 ≠ 音声本文を 16,044 B 受信

本文 hash は保持バイトの一致。アプリの処理・再生完了までは保証しない。

出典： RSS001 ・ RSS006 の限定 HTTP 本文検査

UID 不明 4 単位は、扱い方で説明が変わる

方式	元の許可条件	事後の禁止条件
不明を保持	4 件を評価不能	4 件を評価不能
不明行を削除	4 件の記録が消える	4 件の記録が消える
UID 条件だけ除去	4 件を整合扱い	4 件を不一致候補扱い

削除は情報欠落、条件除去は未確認の対象帰属を追加。外部ツールの誤検出率ではない。

出典： 13 試行の UID アブレーション（ 117 出力、追加試行 0 ）

再現性の確認と、意味の正しさは別に点検する

出力の整合性

25 試行の規則判定を再生成
対応表も照合範囲で一致
原本の変更なし

原本による解釈の点検

公開起動の旧版に UID 保持不具合
原本と訂正版を区別
同じ出力＝正しい、ではない

AI 支援による点検。独立した人手評価・一般精度の検証ではない。

出典： AI 原本点検 4 事例・保存入力の再生成 25 試行

制御 19 試行で、動的のみと併用の判定は一致した

今回、判定精度の向上は示していない。

確認できたこと

静的候補と実測を同じ説明の中で追跡できる

まだ示していないこと

未知アプリへの精度・安全性・作業時間削減

成果は、指定範囲の説明・根拠・限界を対応させた実装と事例評価。

出典：元の取得条件の 19 試行・ 57 処理結果

先行研究との差は、対象と設計範囲として述べる

先行研究	主に扱う対象	本研究との関係
PoliCheck	受信主体・データ型とポリシー	UID 帰属とは異なる概念
PoliGraph	文をまたぐ知識グラフ・根拠文	未指定・根拠追跡は既存
PurPliance	データ利用目的の整合性	本実装は目的を推定しない
DroidBot	UI に基づく入力生成	自動操作自体は先行技術

独自アルゴリズムの新規性は未確立。具体的な実装と事例評価に限定する。

出典： PoliCheck 2020 ／ PoliGraph 2023 ／ PurPliance 2021 ／ DroidBot 2017

本研究の貢献と、適用の限界

具体的な成果

指定操作の解析パイプライン
候補・実測・不足の比較説明
原本・コード版・操作の追跡

限界

単一 AVD ・公開アプリ 1 本
全取得品質 partial
独立人手評価・一般精度は未検証

自然言語ポリシー解析・全機能探索・通信網羅性・安全認証は対象にしない。

結論：証拠から言える範囲を明確にする

対応・差分・判断不能を、
原本に戻れる形で説明する仕組みを実装した。

現在の次工程

原稿の内容確認・著者情報・提出形式の反映

将来の検証

別アプリ・状態統制・独立した説明評価

結論は選定した条件に限定する。整合性は安全性の保証ではない。

出典：既存 25 試行の事後的事例評価

主な出典とデータの所在

PoliCheck	Andow et al., USENIX Security 2020, pp.985–1002.
PoliGraph	Cui et al., USENIX Security 2023, pp.1037–1054.
PurPliance	Bui et al., CCS 2021. DOI: 10.1145/3460120.3484536
DroidBot	Li et al., ICSE Companion 2017.
研究データ	既存 25 試行台帳／ AI 点検表／ 19 試行 3 方式比較／ UID 条件比較

論文・集計データ： takutomiyajima/traffic_detect
配布版 commit： 4a7f1ead6e97c53d23be2f9d0f6008c5bb6a5f4a